

Dependency Health Report — vulnerable-invoice-service

Generated: 2026-06-11T08:30:00Z | Run branch: `fix/depSCAN-20260611-074147` | SHA: `ea2fe54`

Health Score

	Pre-fix (baseline)	Post-fix (this run)	Trend
Score	0 / 100 (floored)	12 / 100	▲ +12 pts
Grade	D — high risk	D — improving	▲
CRITICAL CVEs	4	0	✅ -4
HIGH CVEs	6	8*	⚠️ new post-2026 disclosures
MEDIUM CVEs	5	4	▼ -1
Supply-chain BLOCKs	3	1	✅ -2

*The net increase in HIGH CVEs reflects newly-disclosed 2026 CVEs in log4j 2.17.1 and transitive protobuf CVEs pulled in by mysql — both resolvable by follow-up actions already tracked in issues #13 and #14.

Health score breakdown (post-fix)

Factor	Deduction
Unresolved CRITICAL CVEs (0 × -15)	0
Unresolved HIGH CVEs (8 × -8)	-64
Unresolved MEDIUM CVEs (4 × -2)	-8
Supply-chain BLOCK findings (1 × -10)	-10
Outdated major-version deps (2 × -3)	-6
Score	12 / 100

Projected after required actions complete: replacing mysql connector (clears 5 HIGH + license BLOCK + 1 supply-chain BLOCK), bumping log4j → 2.25.4 (clears 2 HIGH), and resolving guava MAJOR_REVIEW (clears 1 HIGH) → projected **-82 / 100 (Grade B)**.

Executive Summary

- 17 dependencies scanned · 28 CVEs found (pre-fix) · 11 CVEs cleared this run
- 4 CRITICAL CVEs cleared including Log4Shell (CVE-2021-44228, CVSS 10.0)
- Supply-chain: typosquat and HTTP mirror removed; 1 GPL license BLOCK remains
- Remediation: 8 auto-fixes applied; 1 branch pushed; 2 MAJOR_REVIEW issues opened
- Gate outcome: BLOCK — 3 actions required before merge

Top Risks (post-fix, ranked)

Rank	Coordinate	Risk	Band	Top CVE	CVSS	Status
1	mysql:mysql-connector-java:8.0.31	License + CVE	HIGH	CVE-2023-22102	8.3	MAJOR_REVIEW #14
2	com.google.guava:guava:24.1.1-jre	CVE	HIGH	CVE-2023-2976	7.1	MAJOR_REVIEW #13
3	org.apache.logging.log4j:log4j-core:2.17.1	CVE	HIGH	CVE-2026-34479	7.5	Minor bump → 2.25.4
4	org.apache.logging.log4j:log4j-api:2.17.1	CVE	HIGH	CVE-2026-34479	7.5	Minor bump → 2.25.4
5	com.google.protobuf:protobuf-java:3.19.4	CVE (transitive)	HIGH	CVE-2022-3171	7.5	Cleared by #14

Remediation Activity (this run)

Dependency	old → new	CVEs cleared	Branch	Status
log4j-core	2.14.1 → 2.17.1	CVE-2021-44228, CVE-2021-45046, CVE-2021-44832, CVE-2021-45105	fix/depSCAN-20260611-074147	Pushed
log4j-api	2.14.1 → 2.17.1	CVE-2021-44228	fix/depSCAN-20260611-074147	Pushed
jackson-databind	2.9.8 → 2.14.0	CVE-2019-14379, CVE-2019-14540, CVE-2020-36518, CVE-2022-42003	fix/depSCAN-20260611-074147	Pushed
mysql-connector-java	8.0.30 → 8.0.31	CVE-2022-21363	fix/depSCAN-20260611-074147	Pushed
commons-io	2.4 → 2.14.0	CVE-2024-47554	fix/depSCAN-20260611-074147	Pushed
commons-lang3	3.4 → 3.20.0	CVE-2025-48924	fix/depSCAN-20260611-074147	Pushed
com.fastxml.jackson.core:jackson-databind	2.9.8 → REMOVED	Supply-chain (typosquat)	fix/depSCAN-20260611-074147	Pushed
http://insecure-mirror.example.net/maven2	present → REMOVED	Supply-chain (HTTP mirror)	fix/depSCAN-20260611-074147	Pushed

Open PR manually: <https://github.com/sathiskumarperumal/dependency-supplychain-demo/compare/main...fix/depSCAN-20260611-074147>

Supply-Chain Findings

Type	Coordinate	Detail	Action	Status
Typosquat	com.fastxml.jackson.core:jackson-databind:2.9.8	Missing 'er' in groupId	Removed	✅ Resolved
Untrusted HTTP repo	http://insecure-mirror.example.net/maven2	Plain-HTTP MITM vector	Removed	✅ Resolved

License violation	mysql:mysql-connector-java:8.0.31	GPL-2.0 incompatible with permissive policy	Replace → com.mysql:mysql-connector-j	⚠️ BLOCK — issue #14
-------------------	-----------------------------------	---	---------------------------------------	----------------------

Stage 4 Gate Verdict

Check	Result	Key Detail
Tests (mvn clean test)	PASS	2/2 passed, 0 failures
OWASP Dependency-Check	BLOCK	8 HIGH CVEs with available fix
Supply-Chain Audit	BLOCK	GPL-2.0 license violation
Aggregate	BLOCK	Do not merge — 3 actions required

Required actions before merge:

1. **Bump log4j 2.17.1 → 2.25.4** — clears CVE-2026-34479 (HIGH 7.5) + CVE-2026-34480 (HIGH 7.5). Minor version; no MAJOR_REVIEW.
2. **Replace mysql:mysql-connector-java:8.0.31 with com.mysql:mysql-connector-j:9.x** — clears CVE-2023-22102 (HIGH 8.3) + 4 transitive protobuf HIGH CVEs + GPL license BLOCK. Tracked in issue #14.
3. **Resolve guava MAJOR_REVIEW** — clears CVE-2023-2976 (HIGH 7.1). Major version jump; tracked in issue #13.

Human Follow-up Issues

Issue	Title	Status
#13	MAJOR_REVIEW: upgrade guava 24.1.1-jre → 32.0.0-jre	Open
#14	MAJOR_REVIEW: mysql GPL-2.0 license + connector replacement	Open

Trend vs. Previous Run (2026-06-10)

Metric	2026-06-10	2026-06-11	Delta
Health score	0 (floored)	12	▲ +12
CRITICAL CVEs	4	0	✅ -4
Supply-chain BLOCKs	3	1	✅ -2
CVEs total	28	~17	▼ -11
Grade	D	D (improving)	▲

Demo Script

Pre-flight checklist

- ☐ Java 17+: java -version
- ☐ Maven 3.6+: mvn -v
- ☐ Syft 1.x: syft version
- ☐ Gype 0.x: gype version
- ☐ GitHub CLI: gh auth status

- ☐ Repo at vulnerable baseline: `git log --oneline -1` → `72fe788`

Rollback to baseline

```
git checkout main
git reset --hard 72fe788e0d0637f538dd1713c30593958b749b9a
```

Demo beats

1. **Show vulnerability** — open `pom.xml` ; highlight `log4j-core:2.14.1` (Log4Shell) and `com.fastxml.jackson.core` (typosquat).
2. **Detect** — `/depscan-dependency-scanner` → CRITICAL CVEs surface with CVSS scores.
3. **Score** — `/risk_scoring_agent` → ranked backlog, worst dependency at top with rationale.
4. **Fix** — `/depscan-auto-remediation` → one consolidated branch; changelog shows CVEs cleared.
5. **Gate** — `/pr_validation_agent <PR>` → tests + OWASP + supply-chain verdict posted.
6. **Prove** — `/depscan-audit-trail` → health score advances; CRITICAL count → 0; trend shows progress.

Stakeholder Summary

The automated Dependency & Supply-Chain pipeline ran against `vulnerable-invoice-service` on 2026-06-11 and applied safe fixes to all auto-remediable vulnerabilities, including Log4Shell (CVSS 10.0), four critical `jackson-databind` deserialization CVEs, a typosquatted coordinate, and an untrusted plain-HTTP Maven mirror — eleven CVEs cleared in a single automated run. Three follow-up items require human review before the fix branch can be merged: a minor `log4j` bump to 2.25.4, replacement of the MySQL connector (which simultaneously resolves a GPL license policy violation and five transitive HIGH CVEs in `protobuf-java`), and a major-version compatibility review for Guava. All three are tracked in issues #13 and #14 and are ready for human approval without further automated scanning.

Generated by the Dependency & Supply-Chain Plugin — Stage 5 (Audit Trail) · run 2026-06-11 Sources: `depscan-report.json` · `depscan-risk-report.json` · `depscan-supplychain-audit.json` · `depscan-verdict.md`